

Security Incident Reporting Module

Introduction

In today's cyber landscape, we are always waiting for the next security incident. Most organisations and companies the world-over are dependant on technology for their operations. Which this increased use of technology and computer systems, comes a largely increased risk. Security incident reporting serves as a conduit between the identification and remediation of threats. It also facilitates the archival of past incidents, providing an invaluable repository for lessons learned. Having a comprehensive and consistent incident reporting framework is vital.

Effective incident reporting needs to strike a balance between granularity and accessibility, making it comprehensible to both technically savvy and non-technical audiences. The cornerstone of an initial successful response to an incident lies in the capability to promptly identify and categorise the threat. Security incidents can be detected from a wide array of sources but there are 3 main ones that we need to consider:

- Security systems/tools: Tools such as IDS/IPS, EDR, SIEM, AV etc, can generate alerts and indicate a potential breach or attack.
- Human observation: Users may report suspicious activities such as unusual emails or systems behaving weirdly.
- Third party notifications: Partners, vendors or even customers might inform organisations about any vulnerabilities or breaches they are experiencing.

Once we have identified an incident, we need to categorise it to facilitate the prioritisation and allocation of resources. Some examples of incident types:

- Malware
- Phishing
- DDoS Attacks
- Unauthorised Access
- Data Leakage
- Physical Breach

Each incident can then be assigned a severity level:

- Critical (P1)

- High (P2)
- Medium (P3)
- Low (P4)

Be aware that incidents frequently straddle multiple categories and can shift in both category and severity as additional intelligence is gathered.

The Incident Reporting Process

The reporting process serves as the cohesive framework that binds all elements of security incident reporting.

Initial Detection & Acknowledgement

Before any incident can be formally reported, it first must be detected and acknowledged. Detections can come from many different sources. In some cases, the threat actor themselves might trigger the detection, such as during a ransomware attack.

Preliminary Analysis

During this phase, the scope and potential ramifications of the security incident must be ascertained. The incident should be categorised based on our previously established classification and severity metrics.

Incident Logging

Every facet, action, and observation related to the security incident needs to be logged using an established system. Popular platforms for this purpose include JIRA and TheHive. In the absence of such a system, even rudimentary tools can suffice.

Notification of Relevant Parties

Stakeholders must be promptly identified and notifications segmented into:

- Internal communications: For the relevant departments such as IT, legal, PR, and executive teams. In the case of a widespread and severe incident, an organisation-wide notice may be issued.
- External communications: For customers, partners, regulatory bodies, or even the general public.

Detailed Investigation & Reporting

The duration of this phase can vary significantly depending on the scale of the incident. This should result in a comprehensive technical analysis coupled with a compilation of all findings.

Final Report Creation

The culmination of your role as an analyst or incident responder is the creation of a finalised incident report. This document can give regulators, insurers and executive leadership with a detailed account of the incident.

Feedback

Post-incident reflection is essential for enhancing our preparedness for future incidents. This involves revisiting and analysing the incident to identify areas for improvement.

Elements of a Proper Incident Report

Executive Summary

Consider the executive summary as the gateway to the report - it is designed to cater to a large non-technical audience including key stakeholders. This section needs to provide the reader with a succinct overview, key finders, immediate actions taken, and impact on the organisation. Here's a list of what should be contained in the executive summary:

Section	Description
Incident ID	Unique identifier for the incident.
Incident overview	Provide a concise summary of the incident's events including initial summary. State the exact type of incident as well as the estimated time/date of the incident, its duration and whether it is still ongoing.
Key findings	Enumerate any findings that emerged from the incident. What was the root cause? Was a specific CVE exploited? What data, if any, was compromised, exfiltrated or jeopardised?
Immediate actions taken	Outline the immediate measures taken. Was the affected system promptly isolated? Was the root cause identified? Did we engage with any third party services?
Stakeholder Impact	Assess the potential impact on various stakeholders. Did any customers experience downtime? What are the financial ramifications? Was employee data compromised?

Technical Analysis

This section is where we dive deeply into the technical aspects, dissecting the events that transpired during the incident. The following key points need to be addressed:

Section	Description
Affected systems and data	Highlight all systems and data that were potentially accessed or definitively compromised. If data was exfiltrated, specify the volume or quantity if ascertainable.
Evidence sources & analysis	Emphasise the evidence scrutinised, the results, and the analytical methodology employed. For example, if a compromise was confirmed through web access logs, include a screenshot for documentation. Maintaining evidence integrity is crucial so best practice is to hash files to ensure their integrity.
IOCs	Useful for hunting potential compromises across our broader environment or even partner organisations. It may also be possible to attribute the attack to a specific threat group based on IOCs.
Root cause analysis	Within this section, detail the root cause analysis conducted and elaborate on the underlying cause of the incident (for example, vulnerabilities, failure points etc)
Technical timeline	A pivotal component for comprehending the incident's sequence of events. The timeline should include: Recon, Initial compromise, C2 communication, Enumeration, Lateral movement, Data access and exfiltration, Malware deployment, Containment time, Eradication time, Recovery time.
Nature of the attack	Deep-dive into the type of attack, as well as the TTPs employed by the attacker.

Impact Analysis

Provide an evaluation of the adverse effects that the incident has had on the organisations data, operation and reputation. Quantify and qualify the extent of the damage caused. It also assesses the potential business implications, such as financial loss, regulatory penalties and reputational damage.

Response and Recovery Analysis

Outline the specific actions taken to contain the security incident, eradicate the threat, and restore normal operations. This section serves as a chronological account of the measures implemented to mitigate the impact and prevent future occurrences of similar incidents.

Immediate Response Actions

- Identification of compromised accounts/systems: A detailed account of how compromised accounts or systems were identified, including the tools and methodologies used.
- Time-frame: The exact time of detection, down to the minute if possible.
- Method of revocation: Explanation of the technical methods used to revoke access, such as disabling accounts, changing permissions or altering firewall rules.
- Impact: Assessment of what revoking access immediately achieved, including the prevention of data exfiltration or further system compromise.
- Short-term containment: Immediate actions taken to isolate affected systems.
- Long-term containment: Strategic measures, aimed at long-term isolation of affected systems.
- Effectiveness: An evaluation of how effective containment strategies were in limiting the impact of the incident.

Eradication Measures

- Identification: Detailed procedures on how malware/malicious code was identified including forensic analysis.
- Removal techniques: Specific tools or manual methods used to remove the malware.
- Verification: Steps taken to ensure that the malware was completely eradicated, such as checksum verification.
- Vulnerability identification: How were vulnerabilities discovered, including CVEs if possible.
- Patch management: Detailed account of the patching process, including testing, deployment, and verification stages.
- Fallback procedures: Steps to revert the patches in case they cause system instability or other issues.

Recovery Steps

- Backup validation: Procedures to validate the integrity of backups before restoration.
- Restoration process: step-by-step account of how data was restored, including any decryption methods.
- Data integrity checks: Methods used to verify the integrity of the restored data.

- Security measures: Actions taken to ensure that systems are secure before bringing them back online - for example, though reconfiguring firewalls or updating IDS.
- Operational checks: Tests conducted to confirm that systems are fully operational and perform as expected.

Post-Incident Actions

- Enhanced monitoring plans: Detailed plans for ongoing monitoring to detect similar vulnerabilities or attack patterns.
- Tools and technologies: Specific monitoring tools that will be employed and how they will integrate with existing systems.
- Gap analysis: A thorough evaluation of what security measures failed and why.
- Recommendations for improvement: Concrete recommendations based on lessons learned, categorised by priority and timeline for implementation.
- Future strategy: Long-term changes in policy, architecture or personnel training to prevent similar incidents.

Diagrams

The narrative can become exceedingly complex so visual aids should be used.

- Incident flowchart: Illustrate the attack's progression, from initial entry to propagation throughout the network.
- Affected systems map: Depict the network topology, accentuating the compromised nodes. Used colour-coding or annotations to indicate the severity of each compromise (Maltego, Cisco packet tracer etc)
- Attack vector diagram: Use arrows, nodes and annotations to trace the attacker's navigation and exploitation activities visually.

Appendices

This section is a repository for supplementary material that provides additional context, evidence or technical details that are crucial for understanding the incident. This section is the backbone of the report as it offers raw data and artefacts that can be independently verified - adding credibility to the report. This section may include:

- Log files
- Network diagrams

- Forensic evidence
- Code snippets
- Incident response checklist
- Communication records
- Legal and regulatory documents
- Glossary and Acronyms

Industry Best Practices

Root cause analysis should be conducted to prevent future occurrences. Non-sensitive details should be shared with a community of defenders to improve collective cybersecurity. All stakeholders should be updated regularly throughout the incident response process. Findings should be validated by external parties.

Communications

In the midst of any crisis, effective communication is not just beneficial, but is crucial. The significance of adept communications is multi-faceted and can be segmented into the following categories:

Stakeholder Trust

Transparent and coherent communication is instrumental in preserving stakeholder trust throughout an incident. It serves as a testament to an organisation's responsibility, transparency and command over the situation.

Coordination & Efficiency

Alignment among all parties involved is especially vital. A cybersecurity incident is not an isolated event affecting only the technical team ; it has a broader organisational knock-on. Keeping everyone on the same page is essential.

Regulatory Compliance

It is imperative to cross-verify the regulatory compliance mandates specific to your organisation. These guidelines should be explicitly documented in your incident response plan (IRP).

Internal Communications

Whilst often sidelined, your internal communications are pivotal for conveying a consistent message across the organisation. This is especially important if the incident involves information

leakage. Internally we need to ensure immediate notification of all relevant parties, regular updates and briefings for all teams and a feedback loop to facilitate sharing findings and raising concerns.

External Communications

External communications are critical and often encompass a wide array of third parties. Some things we need to consider are:

- Who are the affected parties? - We need to make direct contact with any parties directly impacted by the incident.
- What is our public statement? - We need to be clear and not use technical terms or jargon.
- Who are the associated regulatory bodies? - We may be obliged to inform regulatory entities within a stipulated timeframe.

Navigating Communication Channels

When we are hit with an incident, the way we communicate becomes very important from both a security and a compliance perspective. In the ways of security we need to consider the following:

- Encryption - Is every piece of shared information encrypted? This is a non-negotiable to avoid leaks to other adversaries, the press and the public.
- Authentication and Authorisation: Access to secure communication channels should be heavily restricted. In addition MFA should be enforced.
- Data Integrity: We need to remain certain that messages remain unaltered during transit. Cryptographic hashing techniques can be our best bet to ensure the integrity of our communications.
- Ephemeral Communications: We may wish to use auto-destructing messages. However, consider that you may need to present some of your incident communications to watchdogs or stakeholders.
- Air-gapped communications: We should not be communicating on devices that we believe may be compromised. The most extreme way of doing this in the event of entire domain compromise is to use air-gapped systems.

In terms of what we need to consider from a regulation standpoint, we have:

- Data Privacy Laws: Discussing or sharing data must be done in accordance to relevant data privacy laws.

- Breach Notification Mandates: Certain jurisdictions have clear-cut timelines for breach notifications.
- Record-keeping: Some regulations may require a clear record of all incident-related communications.
- Cross-border Communications: If our incident spills over national borders, the communication rules will change.
- Chain of Custody: If there is even a hint that legal actions might follow the incident, we need to maintain an unbroken chain of custody for all communications. This ensures that if we need to present evidence in court, it is deemed admissible.